

Risk Scoring Report

Project: `vulnerable-invoice-service` · Stage 2 (NVD CVSS-weighted) · Generated 2026-07-03 · Model: `0.5·CVE_severity + 0.3·exposure + 0.2·business_criticality`

Out-of-band alert (not weighted below): `com.fastxml.jackson.core:jackson-databind:2.9.8` is a **typosquat** of `com.fasterxml.jackson.core:jackson-databind` — it never resolves, so it carries no CVSS/usage signal to weight. Treat as **CRITICAL** and remove immediately; do not wait for a score.

Ranked remediation backlog

#	Coordinate	Ver	Band	Risk	Top CVE / issue	Fix
1	<code>com.fasterxml.jackson.core:jackson-databind</code>	2.9.8	HIGH	7.8	CVE-2020-9548 (9.8), 56 CVEs total	2.21.5
2	<code>org.apache.logging.log4j:log4j-core</code>	2.14.1	HIGH	7.8	CVE-2021-44228 — Log4Shell (10.0)	2.15.0 (2.25.4 clears all)
3	<code>org.apache.logging.log4j:log4j-api</code>	2.14.1	HIGH	7.8	CVE-2021-44228 (shared CPE match)	2.15.0 (2.25.4 clears all)
4	<code>com.google.protobuf:protobuf-java (transitive)</code>	3.19.4	HIGH	6.7	CVE-2022-3509 (7.5)	3.25.5
5	<code>com.google.guava:guava</code>	24.1.1-jre	MEDIUM	5.5	CVE-2023-2976 (5.5)	32.0.0
6	<code>org.apache.commons:commons-lang3</code>	3.4	MEDIUM	5.2	CVE-2025-48924 (5.3)	3.18.0
7	<code>commons-io:commons-io</code>	2.4	MEDIUM	4.7	CVE-2024-47554 (4.3)	2.14.0
8	<code>mysql:mysql-connector-java</code>	8.0.30	LOW	2.8	No CVE; GPL-2.0 license violation	8.0.33 (license issue persists — swap driver)
9	<code>com.fasterxml.jackson.core:jackson-core (transitive)</code>	2.9.8	LOW	2.2	none	—
10	<code>com.fasterxml.jackson.core:jackson-annotations (transitive)</code>	2.9.0	LOW	2.2	none	—
11	<code>org.junit.jupiter:junit-jupiter (test)</code>	5.10.2	LOW	1.9	none, outdated	6.1.1
12+	remaining transitive annotation/test libs (jsr305, checker-qual, error_prone_annotations, j2objc-annotations, animal-sniffer-annotations, junit-platform-*/opentest4j/apiguardian)	—	LOW	1.3–1.9	none	—

Full 23-dependency ranked list with component scores: `depscan-risk-report.json`.

Component scores (top items)

Dependency	CVE severity	Exposure	Business criticality	Weighted
jackson-databind	10.0	8.0	2.0	7.8
log4j-core	10.0	8.0	2.0	7.8
log4j-api	10.0	8.0	2.0	7.8
protobuf-java	9.0	6.0	2.0	6.7
guava	6.0	7.0	2.0	5.5
commons-lang3	5.3	7.0	2.0	5.2
commons-io	4.3	7.0	2.0	4.7
mysql-connector-java	0.0	8.0	2.0	2.8

Business criticality is 2.0 (Internal service/batch) across the board: log4j-core / log4j-api are confirmed used directly in DiscountCalculator.java for order-discount logic (no auth/payment/PII code path found); every other dependency is declared in pom.xml but not actually imported anywhere in src/ , so criticality defaults to 2.0 per the scoring rules.

Summary

Band	Count
CRITICAL	0 (weighted formula) — but see typosquat alert above
HIGH	4
MEDIUM	3
LOW	16

Priority recommendations

- P0** — Remove the typosquatted com.fastxml.jackson.core:jackson-databind coordinate (supply-chain, dependency-confusion vector).
- P0** — Upgrade log4j-core / log4j-api 2.14.1 → 2.25.4 (Log4Shell family + 3 newer 2026 CVEs; keep on the 2.x line, 3.0.0 is still beta).
- P1** — Upgrade jackson-databind 2.9.8 → 2.21.5+ (latest available 2.22.0); 56 known CVEs, unused in code so safe to bump aggressively.
- P1** — Pin protobuf-java (transitive via mysql-connector-java) to ≥3.25.5 via dependencyManagement , or drop the MySQL driver entirely (also clears the license issue below).
- P2** — Replace mysql-connector-java (GPL-2.0) with MariaDB Connector/J (LGPL-2.1) or the approved internal driver.
- P2** — Upgrade guava → 33.6.0-jre, commons-lang3 → 3.20.0, commons-io → 2.22.0 (routine, low-criticality but each carries a real CVE).
- P3** — Bump test-only junit-jupiter 5.10.2 → 6.1.1 when convenient.

Machine-readable source: depscan-risk-report.json . Generated by the Dependency & Supply-Chain Plugin — Stage 2.